Roles y permisos

Las acciones y sus métodos MVC se declaran en `routes/web.php`. `AuthMiddleware` deniega las rutas no autorizadas antes de ejecutar el controlador; `CsrfMiddleware` protege las mutaciones POST de esa capa. La API tokenizada usa autenticación Bearer propia, descrita más abajo. El rol se vuelve a comprobar en el servidor para las decisiones de ofertas y convenios.

Alcance de Observador

Observador es un perfil de auditoría de solo lectura, destinado a consultar el estado operativo de FCT sin gestionar expedientes ni tomar decisiones.

Puede:

- Consultar asignaciones y su estado en modo de solo lectura. Los nombres del alumnado se sustituyen por «Alumno anonimizado»; no se muestran correos ni tutores de empresa.
- Consultar datos de seguimiento y calificaciones anonimizados.
- Consultar el listado de convenios con empresa, ciclo, fechas y estado. Esta vista no incluye enlaces, rutas ni descargas de PDF.
- Consultar el catálogo autenticado de ofertas aprobadas.

No puede:

- Aprobar o rechazar ofertas o convenios, asignar/cerrar prácticas, registrar notas, administrar cuentas ni ejecutar otras operaciones POST de negocio.
- Descargar convenios ni consultar documentos privados.
- Consultar información identificable del alumnado.

El único POST disponible es `logout`, para invalidar la propia sesión; es una excepción de seguridad y no cambia el estado de negocio. El rol no cuenta con permiso de escritura en rutas de gestión.

Matriz resumida

Perfil	Alcance principal
Invitado	Inicio, registro, login y recuperación. El catálogo de ofertas requiere sesión y responde 403 a visitantes sin autenticar.
Alumno	Expediente propio, edición de perfil, disponibilidad, asignaciones propias, calificaciones propias y datos de interés de su empresa asignada. No ve el catálogo general de ofertas ni expedientes de terceros.
Empresa	Sus ofertas, convenios y sedes; puede consultar ofertas aprobadas. No decide sus revisiones.
Coordinador	Consulta y seguimiento de ofertas/convenios, asignación y cierre de prácticas, calificaciones y consultas. No puede aprobar o rechazar ofertas ni convenios.
Administrador	Gestión de usuarios y decisiones sobre ofertas/convenios; comparte la gestión de asignaciones y calificaciones. Es el único rol con acceso a la administración de integraciones: `integraciones` (consola API) y `api-tokens` (emisión y revocación de tokens).
Observador	Solo lectura, con anonimización y sin acceso a documentos privados, según el alcance anterior.

Privacidad del alumnado

`GET empresa-asignada` está limitado al rol Alumno y devuelve solo los datos de interés vinculados a una asignación activa de la cuenta autenticada: nombre y categoría de empresa, ciclo y periodo. No recibe un ID de alumno desde el cliente y no devuelve datos de contacto privados. Si no existe una práctica activa, responde con el contrato JSON de error y estado 404.

El listado general `GET ofertas` está limitado a cuentas autenticadas de empresa y personal. No se concede a Alumno ni a visitas sin sesión. Los datos de empresa solo se presentan al alumno cuando existe una asignación confirmada.

Revisión y responsabilidades

La lista `GET revisar-ofertas` y la revisión documental de convenios permanecen disponibles para Administración y Coordinación. Las mutaciones `POST revisar-oferta` y `POST resolver-convenio` son exclusivas de Administrador; los controladores vuelven a comprobar el rol para evitar decisiones fuera de la política aunque se invoquen directamente.

La política de roles usa los nombres reales del esquema (`Administrador` , `Coordinador` , `Observador` , `Empresa` , `Alumno`). No se inventan roles `Director` ni `Guest` en la base de datos.

El archivo `GET archivo-convenios` está reservado a Administrador. Muestra todos los estados, los datos de revisión y los eventos de auditoría asociados. Los PDF permanecen en almacenamiento privado y se sirven mediante la ruta autorizada `GET descargar-convenio` .

API tokenizada

Las reglas anteriores describen las acciones MVC de `routes/web.php` . La API de tokens se implementa por separado en `public/api.php` y tiene su propia matriz de permisos. Actualmente, las revisiones de ofertas y convenios por API (`PATCH`) y por MVC están reservadas a Administrador; no infieras el resto de permisos API a partir de la matriz MVC.

La anonimización de Observador tampoco se aplica automáticamente a las respuestas REST. En la implementación actual, `GET /alumnos` devuelve nombre, apellidos y correo, y `GET /asignaciones` devuelve nombre y apellidos del alumno; esos recursos no devuelven DNI ni número de Seguridad Social. Concede tokens de forma restrictiva y ten en cuenta esos campos al usarlos. La API conserva el sobre JSON discriminado de `JsonResponse`; las listas añaden `items` y `meta` dentro de `data`, y el código de error se envía en la cabecera `X-API-Error-Code`.

Consulta la documentación de API REST para la matriz completa, el formato de respuestas y las rutas disponibles.